

Performance Review & Self-Assessment Report (2025–2026)

Employee: Chinmay Dhok

Role: Sr. Information Security Analyst

Organization: OnlineSales.ai (Osmos.ai)

Review Period: November 2025 – August 2026

Executive Summary

During the review period from November 2025 to August 2026, the Information Security function delivered critical advancements across cloud security governance, code supply chain protection, regulatory certifications, and enterprise SaaS optimization.

A dual focus governed this period:

1. **Strengthening Compliance and Defensive Architecture:** Successfully led the organization through high-stakes external audits (including ISO 27001:2022 and SOC 2 Type II) and completed extensive Third-Party Risk Management (TPRM) assessments to unlock key enterprise deals with partners like dunnhumby, PayPal, Pine Labs, and BharatPe.
2. **Improving Operational & Endpoint Resilience:** Conducted deep-dive audits of internal systems, remediating severe code repository vulnerabilities, stabilizing endpoint management agents, and significantly optimizing SaaS licensing expenses across Google Workspace and Gemini AI platforms.

Core Metrics Summary

Strategic Focus Area	Primary Metric / Outcome	Organizational Impact
Code Supply Chain	524 Repositories Audited & Remediated	Zero active IOCs/malware; 42 repositories patched for high-severity Axios vulnerabilities.
Certifications & Audits	0 Major Non-Conformities	ISO 27001:2022 surveillance audit successfully completed; SOC 2 Type II report issued.
Endpoint Security	90%+ Fleet Stability achieved	Realigned MDM configurations, eliminating severe Mac battery/CPU overhead, and established JumpCloud/Hexnode evaluations.
Identity & Access	267 GWS Accounts Re-architected	Streamlined licensing tiers, purged stale suspended assets, and right-sized 56 Gemini AI licenses.
Enterprise TPRM	100% On-Time Partner Approvals	Unlocked commercial partnerships with dunnhumby, PayPal, Pine Labs, and BharatPe.

Section 1: Security Fixes & Infrastructure Governance

1.1 GCP Access Management & Network Security

To establish a robust zero-trust security perimeter across our Google Cloud Platform (GCP) environments, a comprehensive Tech Spec Review was conducted. Access models were upgraded from broad administrative permissions to granular, role-based access control (RBAC). Furthermore, secure remote access was integrated via Tailscale, establishing encrypted, audit-logged connectivity to internal cloud networks while decommissioning insecure legacy VPN points.

1.2 GitHub Repository & Code Supply Chain Security

Conducted an enterprise-wide security audit covering 524 code repositories within the organization's GitHub infrastructure.

- **Supply Chain Audit:** Automated evaluation confirmed zero active malware or Indicators of Compromise (IOCs) across all active repositories.
- **Dependency Safe-Pinning:** Implemented strict semantic version pinning for critical packages, including `litellm`, eliminating potential exposure to upstream supply chain injection attacks.
- **Vulnerability Remediation:** Identified and remediated critical high-severity vulnerabilities in `Axios`, upgrading 42 affected repositories to version `>= 1.8.2`. Detailed tracking is documented in the [GitHub Details Audit Log](#).
- **Static Code Analysis Pipeline:** Integrated CodeAnt and automated CodeReview security dashboards directly into GitHub Actions CI/CD pipelines. This enforcement blocks unsafe pull requests prior to merging. Details are reviewed in the [CodeAnt Details Repository](#).

1.3 Gmail BIMl (Blue Tick) Deployment

Led the end-to-end technical deployment of Brand Indicators for Message Identification (BIMl) for the primary domain (`osmos.ai`). Obtained and validated a Verified Mark Certificate (VMC) and aligned DMARC policies (`p=reject`). This established domain-level authentication, displaying the verified blue checkmark in email clients and preventing phishing attacks spoofing the corporate domain.

1.4 Secure GCS Bucket Provisioning

Designed and deployed production-grade Google Cloud Storage (GCS) buckets for developer content management systems, specifically establishing os-developer-cms-stag-bucket (staging) and os-developer-cms-prod-bucket (production). Applied strict compliance configurations:

- Enforced Uniform Bucket-Level Access (UBLA) to eliminate individual object ACL drift.
- Enabled Public Access Prevention (PAP) to enforce complete private access.

1.5 Stability & Monitoring Improvements

Enhanced cloud operational resilience by engineering custom real-time alerting modules:

- **Cloud SQL Monitoring:** Configured memory, CPU, and connection spike detection alerts to prevent database degradation.
- **Hades Monitor:** Implemented continuous service health monitoring for the internal Hades backend architecture, enabling real-time incident notification and reducing Mean Time to Detect (MTTD).

1.6 Endpoint Fleet Security Audit & MDM Policy Optimization (November 2025 – January 2026)

Following a directive from Shantanu Harkut (VP of Engineering) in November 2025 to audit internal infrastructure, a comprehensive evaluation of endpoint security and MDM policies was executed (documented in the [Security Review for Internal Infrastructure Email Thread](#)).

- **The "Intune Tax" Findings:**
 - **Mac Hardware Degradation:** The 20–30% battery drain and overheating reported by macOS users was traced directly to CPU usage spikes from the Intune Management Agent (IME) during aggressive policy retry loops.

- **The Linux Blind Spot:** Linux machines remained largely unmanaged, creating a compliance gap in central SSH key management and patching.
- **Identity Fragmentation:** Users experienced a fragmented experience due to a lack of true Single Sign-On (SSO) between local device logins and Google Workspace credentials.
- **Phase 1: Immediate Stabilization (Executed Dec 2025 – Jan 2026):**
 - Guided Pramod Nikam (Senior System & Network Admin) to remove conflicting legacy configurations that forced the Intune agent into infinite loop cycles and realigned OS update windows to IST.
 - Completed internal user testing on Chinmay's and Kunal's devices by January 7, 2026. Following thorough data validation, Pramod finalized testing on January 15 and successfully rolled out the stabilized policies company-wide on January 30, 2026.
- **Phase 2: Strategic Modernization:**
 - Initiated parallel evaluations of "Google-Native" platforms to resolve identity fragmentation and the Linux management gap.
 - **Option A (JumpCloud):** Collaborated with Rockladder to schedule and run a technical JumpCloud product demo on January 7, 2026, targeting unified identity/device management for Mac, Windows, and Linux.
 - **Option B (Hexnode UEM):** Triggered a trial of Hexnode to assess its use of Apple's native lightweight MDM framework (which permanently solves the agent battery issue) and evaluate potential licensing cost savings (~\$5/device vs. ~\$16+ competitor average).

Section 2: Compliance, Certifications, and Policy Audits

2.1 ISO 27001:2022 Certification

Successfully led the organization through the high-stakes Stage-2 Surveillance Audit conducted by INTERCERT on June 3–4, 2026. The external audit evaluated

Information Security Management System (ISMS) controls across technical, physical, and operational domains.

- **Outcome:** Achieved ISO 27001:2022 re-certification with **zero major non-conformities**. Official completion records are archived in the [Certifications Reference Audit Mail](#).

2.2 SOC 2 Type II Compliance

Managed the continuous compliance monitoring framework and audit lifecycle for the evaluation period spanning March 1, 2025 – February 28, 2026, in partnership with external auditors Accorp Partners. Successfully validated all Trust Services Criteria—Security, Availability, and Confidentiality—yielding an unqualified SOC 2 Type II audit report with zero exceptions.

2.3 GDPR, CCPA, and PDPA Compliance Audits

Executed global data protection and privacy audits using the Scrut Automation platform. Evaluated cross-border data transfer mechanisms, cookie consent management systems, data subject access request (DSAR) response SLAs, data minimization principles, and retention schedules. The final assessment earned an overall "Satisfactory" rating across GDPR (EU), CCPA (California), and PDPA (Singapore) frameworks.

2.4 DPDPA Compliance

Achieved complete operational alignment with India's Digital Personal Data Protection Act (DPDPA). Successfully earned official Scrut DPDPA compliance badges. Finalized standardized social media marketing opt-in templates, privacy disclaimers, and structured data breach notification workflows.

2.5 Scrut Policy Review & Asset Inventory

Modernized the organizational policy framework by conducting a comprehensive review of 54 HR and Information Governance policies.

- Leveraged LLM-assisted analysis combined with manual oversight to remove obsolete, legacy policy language and harmonize terms across international operating units.
- Updated asset management ledgers to ensure 100% endpoint registration.
- Maintained active tracking through the [Scrut Task Review Tracker](#) and the centralized [Compliance Evidence Tracking](#) repository.

Compliance Framework	Audit Authority	Status / Result	Key Artifact / Focus Area
ISO 27001:2022	INTERCERT	Certified (0 Major NCs)	Stage-2 Surveillance (June 3-4, 2026)
SOC 2 Type II	Accorp Partners	Report Issued (Clean)	Verification Period: Mar 1, 2025 – Feb 28, 2026
GDPR / CCPA / PDPA	Scrut Automation	Satisfactory Rating	Global Privacy & DSAR SLA Validation
DPDPA (India)	Scrut / Internal	Fully Compliant	Consent Forms & Official Badges Finalized
Governance Policies	Internal / Scrut	54 Policies Modernized	LLM-assisted Review & Legacy Clause Purge

Section 3: Operational & Enterprise IT Operations

3.1 Google Workspace (GWS) License Migration

Led a domain-wide migration and license restructuring across 267 Google Workspace accounts. The initiative eliminated duplicate licensing tiers, optimized overall SaaS expenditure, and cleaned up stale organizational units.

- **Enterprise Standard:** Provisioned 200 power-user accounts with enhanced security features (Vault, advanced DLP, Context-Aware Access).

- **Business Starter:** Right-sized 67 operational accounts requiring basic collaboration tools.
- **Account Sanitization:** Identified and permanently deleted suspended, offboarded, and unassigned licenses, preventing recurring subscription waste. Migration details are tracked in the [GWS License Migration Tracker](#).

3.2 Gemini License Cost Optimization

Audited the usage patterns of 56 enterprise Google Gemini AI licenses (comprising 37 Business and 19 Enterprise tiers). Reallocated dormant or underutilized seats directly to active engineering and business teams, ensuring optimal utilization and reducing monthly SaaS cost metrics. Real-time license mapping is available in the [Gemini License Allocation Sheet](#).

3.3 BCP Testing & Intercompany Documentation

Owned the execution and documentation of the Business Continuity Plan (BCP) and Disaster Recovery (DR) testing lifecycle:

- Conducted simulated operational outage scenarios to validate Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO).
- Reviewed and updated intercompany Data Processing Agreements (DPAs), Service Level Agreements (SLAs), and internal security governance documentation quarterly to ensure cross-entity compliance.

SaaS / IT Service	Pre-Optimization State	Post-Optimization State	Quantitative Impact
Google Workspace Tiers	Unstructured, unmonitored tiers	200 Enterprise / 67 Starter	100% account accountability; reduced tier cost
Suspended GWS Accounts	Unassigned Paid Seats	Zero Stale Active Seats	Eliminated recurring license waste

SaaS / IT Service	Pre-Optimization State	Post-Optimization State	Quantitative Impact
Gemini AI Subscriptions	56 Unmonitored Seats	37 Business / 19 Enterprise	Reallocated dormant seats to active users; zero idle cost

Section 4: Third-Party Risk & Vendor Assessments

4.1 PayPal Background Verification (BGV) Compliance

To satisfy strict enterprise onboarding requirements mandated by PayPal, updated internal employee background verification protocols. Conducted a detailed vendor evaluation comparing background check providers (Quinfy vs. Securitas). Selected and integrated Quinfy, providing a cost-effective, SMB-friendly platform while meeting PayPal's stringent security standards.

4.2 Pine Labs InfoSec & DPA Integration

Facilitated the security review and procurement milestone for Pine Labs:

- Processed and resolved complex Data Processing Addendum (DPA) technical queries.
- Formatted official Information Security support documentation and updated cloud network architecture topologies.
- Successfully secured technical approval from Pine Labs' enterprise risk committee.

4.3 BharatPe TPRM Self-Assessment

Authored technical responses and compiled evidence for BharatPe's Third-Party Risk Management (TPRM) audit. Successfully addressed complex questionnaires covering encryption standards, incident response protocols, disaster recovery plans, and network isolation controls. All submitted evidence and formal response matrices are cataloged in the [BharatPe TPRM Self-Assessment Sheet](#) and the [BharatPe Questions Email Thread](#).

4.4 dunnhumby Third-Party Risk Assessment (TPRM) (January 2026)

In January 2026, compiled and delivered a comprehensive TPRM response to the dunnhumby team, collaborating directly with Brent Payne (Global Organisational Resilience & Internal Investigations Manager) and Anzar Berqi (detailed in the [dunnhumby TPRM Email Thread](#)).

- **Submission Elements:**
 - **Security & Compliance Standards:** Provided verified evidence of full adherence to SOC 2 Type II, ISO 27001, GDPR, and CCPA standards.
 - **Uptime & Failover Architecture:** Guaranteed a 99.9% Uptime SLA backed by multi-region, geo-redundant GKE cluster topology across North America and the EU. Documented failover mechanics utilizing Google Cloud Load Balancing, Cloud Armor (WAF), and automated DNS routing, with an RTO target of ≤ 4 hours and RPO target of ≤ 15 minutes as outlined in the [Osmos Service Level Agreement](#).
 - **Monitoring & Alerts:** Outlined real-time observability pipelines (automated health checks executing every 60 seconds) with continuous alerting via Cloud Monitoring and status transparency via [Osmos API Status Page](#).
 - **Data Residency & Privacy controls:** Documented secure data hosting regions (us-central1, with opt-in Belgian/Frankfurt regions for GDPR compliance). Detail data handling standards including irreversible SHA256-hashing of PII for audience targeting, and configurable data retention policies (13-month default for campaign data, 35 days for event performance validation, and 7 years for financial records).
- **Security trust Verification:** Provided secure access to verified audit reports, penetration tests, and security certificates via the [Osmos Security Trust Vault](#).
- **Auditor Assessment:** Brent Payne praised the submission for its comprehensiveness. Deep-dive evaluation sessions were scheduled to finalize technical clearance.